

Arquitectura funcional actual y objetivo operativo

Documento técnico consolidado: repositorio, módulos, datos, separación multiempresa, controles, operación cloud y arquitectura objetivo.

Alcance

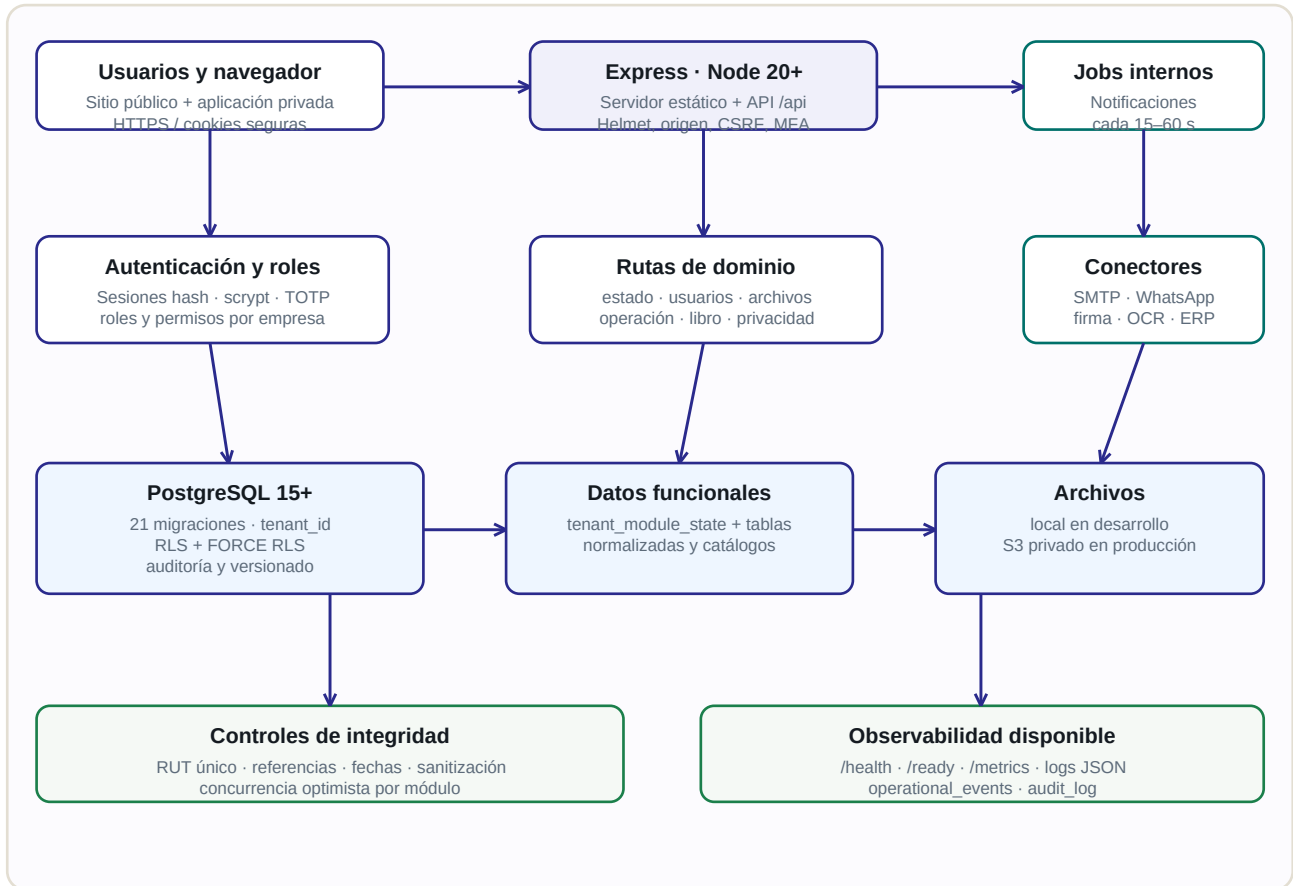
Describe lo que funciona hoy en el código de Nexo Klar y cómo debe quedar la plataforma cuando AWS, monitoreo, continuidad e integraciones estén operativos. No asume servicios externos no configurados.

Referencia	Valor
Versión funcional	Nexo Klar Cloud 7.7.0
Backend	Node.js 20+ · Express 5 · API REST
Persistencia	PostgreSQL 15+ · 21 migraciones · RLS
Archivos	S3 privado preparado para producción; disco local solo en desarrollo
Seguridad	scrypt, sesión hash, cookie segura, CSRF, MFA obligatorio en producción
Fecha	11 de agosto de 2026

Lectura técnica. El repositorio ya contiene una plataforma multiempresa operativa y validaciones automatizadas. “Objetivo operativo” significa que la infraestructura AWS, proveedores externos y controles de continuidad se han configurado y probado con cuentas reales.

1. Arquitectura funcional que opera hoy

La aplicación se ejecuta como un servicio Express que entrega la interfaz desde **public/** y expone una API bajo **/api**. La interfaz usa HTML, CSS y JavaScript modular; no corresponde a una aplicación React/Vite.



Flujo de datos actual: la sesión valida identidad y tenant; el middleware exige origen, CSRF y MFA; la ruta de negocio ejecuta una transacción con contexto de tenant; PostgreSQL aplica RLS; las operaciones relevantes generan auditoría y eventos de error.

2. Servicios y rutas que funcionan hoy

Área API	Uso funcional	Controles
/api/auth	inicio de sesión, MFA, recuperación, sesiones y registro controlado	contraseña script, rate limit, TOTP, cookies HttpOnly
/api/state	estado modular por empresa y concurrencia optimista	versión por módulo, conflictos 409, RLS
/api/users y /api/tenants	usuarios, roles, clientes SaaS y gobierno Domian	roles, tenant, auditoría y suspensión lógica
/api/files	carga, descarga y baja lógica de evidencias	MIME permitido, 25 MB, SHA-256, deduplicación, AV requerido en producción
/api/operations	operación, recursos, costos, inventario, notificaciones y eventos	transacciones, tenant_id, auditoría
/api/work-books	libro de obra, anotaciones, firmantes y callbacks de firma	folio, estado, adjuntos, proveedor configurado
/api/privacy y /api/audit	gobierno de datos, evidencias y bitácora	roles, histórico append-only
/api/integrations y /api/settings	secretos por empresa, conectores y catálogos	AES-256-GCM para secretos de integraciones
/api/data-transfer	importación, exportación y plantillas	validaciones, duplicados, relaciones y registro de evento

Planificador interno: procesa notificaciones configuradas por empresa, correos SMTP, WhatsApp, informes programados y errores de entrega. Usa locks de trabajos para evitar que una tarea se ejecute dos veces mientras está en curso.

3. Arquitectura de datos y separación de clientes

Capa de aislamiento	Mecanismo implementado	Efecto
Identidad	RUT de empresa + usuario + sesión revocable	la API deriva empresa y rol desde la sesión, no desde el navegador
Aplicación	authenticate, requireMfa, requireCsrf, requireOrigin, allowRoles	ninguna ruta privada opera sin sesión y control correspondiente
Transacción	withTenant() abre BEGIN y establece app.current_tenant_id	toda consulta tenant-aware corre dentro de contexto explícito
PostgreSQL	tenant_id, políticas RLS y FORCE ROW LEVEL SECURITY	la BD filtra incluso si una consulta olvida una condición de empresa
Archivos	clave tenants/{tenantId}/objects/{sha} y metadatos tenant_id	una empresa no debe descargar el archivo de otra
Configuración	tenant_settings, catálogos, integraciones y perfil comercial por tenant	cada empresa parametriza sin cambiar vistas, listas o secretos de otras
Auditoría	audit_log, entity_change_history, integration_events y operational_events	cada cambio queda asociado a empresa, usuario y entidad

Prueba E2E imprescindible

Empresa A, B y C deben cargar clientes, personas, archivos, inventario y exportaciones. Desde cada cuenta se valida ausencia total de datos ajenos, incluso con ID manipulado, URL de archivo o solicitud de exportación.

4. Datos, dominios y reglas de integridad

Dominio	Datos principales	Reglas y relación
Comercial	prospectos, clientes, contratos, firmas, órdenes de servicio	cliente → contrato → orden; vigencia, responsable, presupuesto y documentos
Personas	trabajadores fijos, por proyecto, disponibles, subcontratos	RUT único por empresa, estado operativo, asignación, restricciones y trayectoria
Cumplimiento	documentos, cursos, exámenes, salud, credenciales, habilitación	matriz de requisitos por cliente/contrato/orden/cargo; vencimientos y bloqueo
Recursos	EPP, vehículos, maquinaria, equipos, bodega, alojamiento, turnos	asignaciones, stock, movimientos, vida útil, disponibilidad y costos
Operación	libro de obra, incidentes, CAPA, comunicaciones, horas y evidencias	folio, responsable, compromiso, firma, observaciones, historial y cierre
Gobierno	usuarios, permisos, catálogos, privacidad, auditoría, tickets	parámetros, conservación, cambios, soporte y administración global

Reglas implementadas: RUT único por empresa, referencias válidas entre entidades, fechas coherentes, bloqueo de contenido HTML ejecutable, archivos Base64 no persistidos, hashes de archivos y control de versión optimista por módulo.

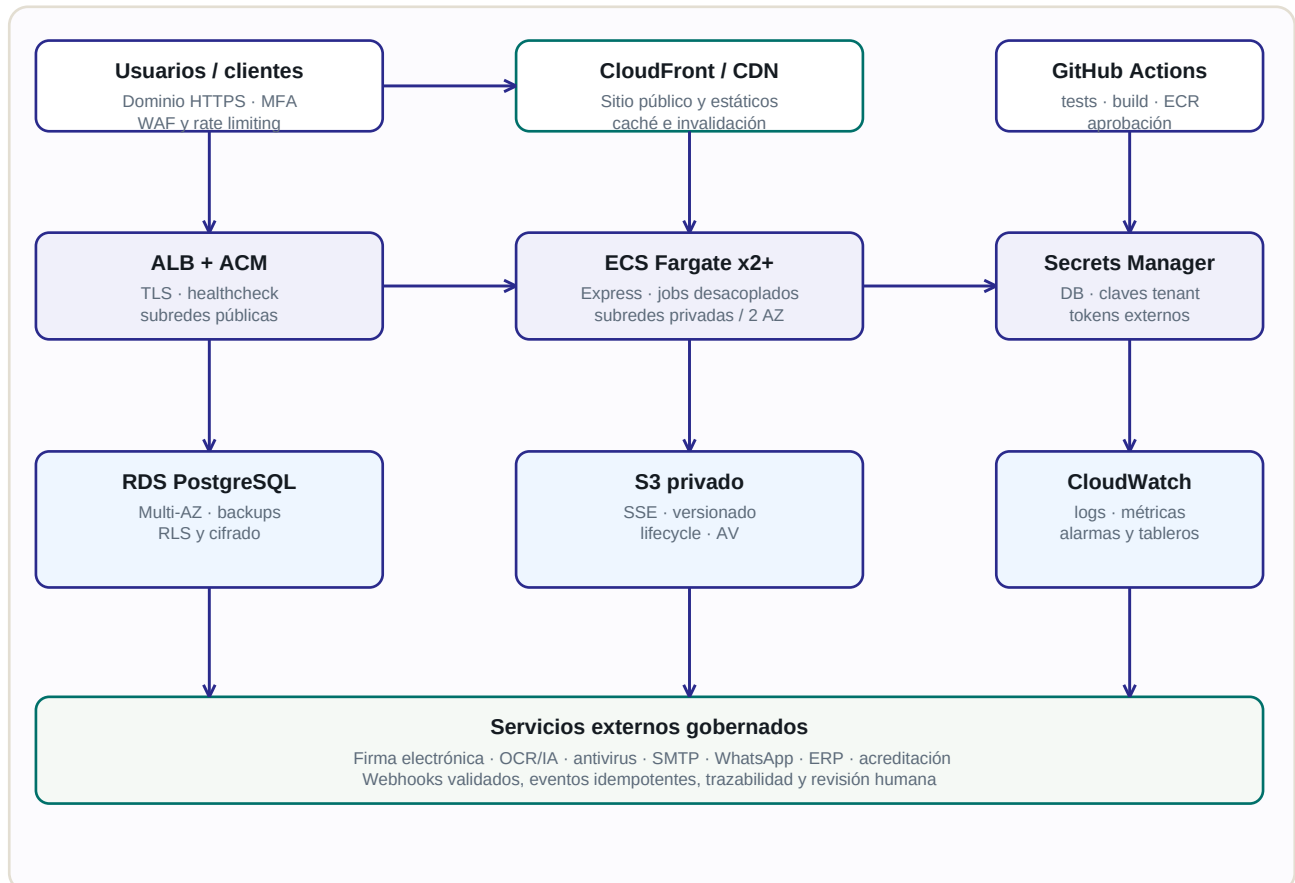
5. Seguridad actual y cierre necesario

Control	Funcionando hoy	Para operar producción
Credenciales	script N=16384, r=8, p=1; mínimo 12 caracteres con mayúscula, minúscula y número.	política de credenciales comprometidas, procedimiento de soporte y revisión de tasas
MFA	TOTP de 6 dígitos, códigos de recuperación, MFA_REQUIRED exigido en validación productiva.	enrolamiento guiado, resguardo de recuperación y simulacro de pérdida
Sesiones	token aleatorio hash SHA-256, expiración, revocación, cookie HttpOnly/Secure/SameSite Strict.	HTTPS real, monitoreo de sesiones anómalas y cierre por incidente
API	Helmet, CSP actual, límite JSON 8 MB, CSRF, validación de origen y roles.	CSP sin unsafe-inline donde sea viable, WAF, pentest y revisión OWASP
Archivos	lista de MIME, máximo 25 MB, SHA-256, almacenamiento seguro y estado malware.	proveedor AV operativo, cuarentena, reescaneo, alertas y lifecycle
Secretos	AES-256-GCM para secretos por tenant; entorno valida TENANT_SECRET_KEY.	AWS Secrets Manager, rotación, IAM mínimo y no registrar secretos en logs

Protección de datos. La plataforma tiene controles técnicos, pero la operación debe implementar inventario de tratamientos, base jurídica, periodos de retención, derechos de titulares, respuesta a brechas y responsables conforme a Ley 21.719.

6. Diagrama: arquitectura objetivo totalmente operativa

El siguiente diagrama representa la configuración objetivo. No debe afirmarse como desplegada hasta contar con una cuenta AWS, recursos, certificados, secretos, proveedores externos y evidencias de pruebas de recuperación.



Principio de operación: un solo punto público HTTPS; servicios y datos en subredes privadas; acceso IAM mínimo; dos zonas de disponibilidad; secretos centralizados; documentos cifrados; observabilidad y alertas proactivas.

7. Diseño funcional completo cuando esté operativo

Paso	Flujo funcional	Resultado
1. Acceso	Usuario inicia sesión con RUT de empresa, correo, contraseña y MFA.	Sesión segura con tenant, rol, permisos y CSRF.
2. Gestión	Cliente → contrato → orden de servicio; se asignan personas, recursos y requisitos.	Operación con contexto comercial y operativo único.
3. Cumplimiento	Documentos, cursos, exámenes, credenciales y archivos pasan por estados y validación.	Estado habilitado/restringido y alertas por brecha.
4. Ejecución	Libro de obra, inventario, hotelería, vehículos, incidentes, CAPA y comunicaciones.	Evidencia, costos, avances, responsabilidades y tiempos.
5. Integración	Eventos llaman firma, OCR, AV, correo, WhatsApp, ERP o acreditación oficial.	Resultado idempotente, auditado y con revisión humana.
6. Decisión	Panel, alertas, reportes y analítica leen entidades normalizadas y estado operativo.	Decisiones con datos por empresa, cliente, contrato u orden.
7. Continuidad	Backups, monitoreo, alarmas, runbook, restauración y control de releases.	Servicio recuperable, medible y operable en el tiempo.

8. AWS y despliegue: configuración técnica

Componente	Configuración objetivo	Criterio de aceptación
VPC / red	ALB en subredes públicas; ECS y RDS en privadas; 2 AZ; NAT o endpoints VPC.	RDS no público; ECS no accesible desde internet; SG mínimo.
ECS Fargate	mínimo 2 tareas, 1 vCPU/2GB inicial, health /api/health y readiness /api/ready.	rolling o blue/green, rollback y escalamiento por CPU/memoria.
RDS PostgreSQL	PostgreSQL 15+, Multi-AZ, cifrado, backups y parámetros de conexión.	restauración aislada probada; RPO/RTO definidos.
S3 documentos	block public access, SSE, versionado, lifecycle, task role.	archivo privado solo accesible con autorización; AV limpio.
ECR / CI	imagen por commit, escaneo, build reproducible y migración controlada.	tests pasan antes de desplegar; no migraciones concurrentes.
ACM / DNS / WAF	dominio, HTTPS, redirección 80→443, reglas de protección.	TLS vigente, cabeceras, rate limit y logs.
CloudWatch	logs, dashboards y alarmas 5xx, latencia, CPU, errores, jobs fallidos.	notificación llega a responsables y se registra resolución.
Secrets Manager	DATABASE_URL, TENANT_SECRET_KEY, métricas y tokens de proveedores.	sin secretos en Git; roles IAM limitados y rotación definida.

Pipeline recomendado: Pull request → tests → build Docker → escaneo → ECR → migración puntual en staging → smoke tests → aprobación → despliegue ECS → readiness → monitoreo → rollback si falla. El repositorio trae los artefactos base; se debe habilitar el pipeline CI/CD en la organización de GitHub y AWS.

9. Observabilidad y continuidad operativa

Señal	Fuente	Alarma / respuesta
Aplicación	logs JSON con requestId, tenantId, status y duración	errores 5xx, latencia, picos por endpoint; ticket y revisión
Salud	/api/health, /api/ready, ECS healthcheck	tarea no saludable, readiness fallida, servicio bajo mínimo
Base de datos	RDS/CloudWatch y métricas de pool	conexiones, CPU, almacenamiento, slow query, backup fallido
Procesos	notification_jobs y operational_events	trabajo fallido, trabajo bloqueado, proveedor no disponible
Archivos	S3, antivirus y file_objects	AV no disponible, archivo bloqueado, error de lectura/escritura
Seguridad	audit_log, auth y WAF	intentos de acceso, cambios de permisos, exportaciones anómalas
Continuidad	backups, restauración y runbook	simulacro trimestral, RPO/RTO, acciones correctivas

Recomendación: desacoplar el planificador de notificaciones del proceso web cuando la carga crezca. En la primera etapa puede operar en ECS; a escala, ejecutar un worker dedicado y usar EventBridge/SQS para mayor aislamiento y reintentos.

10. Estado real y plan de madurez

Nivel	Estado actual	Siguiente condición
Código y funcionalidad	Implementado: módulos, API, datos, RLS, roles, sesiones, auditoría, archivos, jobs y tests.	Mantener QA completo por release y crecimiento progresivo de entidades normalizadas.
Preproducción	Preparado: Docker, Compose, migraciones, validaciones de entorno y plantilla ECS.	Levantar staging con AWS, datos sintéticos y pruebas E2E de 3 tenants.
Producción	No puede declararse final solo con el código.	Configurar AWS, DNS/TLS, MFA, S3, RDS, AV, secretos, monitoreo y backups.
Integraciones	Conectores y eventos preparados.	Contratar/configurar proveedor y validar sandbox, webhook, errores y trazabilidad.
Continuidad y seguridad	Controles de aplicación presentes.	Pentest, DRP, restauración, WAF, alarmas y gobierno Ley 21.719.

Dictamen técnico

Nexo Klar está arquitectónicamente preparado para una implementación productiva controlada. El siguiente paso no es otro cambio de interfaz: es configurar y probar el entorno cloud con los controles de operación, seguridad y continuidad que convierten el producto en un servicio SaaS real.